Assignment 2: Analysis of Competing Hypotheses: Aurora Biotech Labs

Clement Ampofo · CIS*6530 Cyber Threat Intelligence and Adversarial Risk Analysis · Deliverable 2.1: ACH matrix

Key: C = Consistent · I = Inconsistent · NA = Not applicable / diagnostic-neutral. Rows 1 to 11 are scenario evidence (all retained). Row E12 (shaded yellow) and assumptions A1 to A4 are the student's own additions, not scenario facts. The most diagnostic items are 6, 9 and 4 with E12 (report section 3). Items 1, 7, 8, 10 and 11 are consistent with all or nearly all hypotheses and confirm very little.

Evidence item	H1 State-linked espionage	H2 Independent insider	H3 Cybercriminal intrusion	H4 Benign / false alarm	H5 Competitor-directed insider (added)	Justification / notes
1. Bulk download then resignation	C	C	NA	C	C	Collecting data just before leaving fits every theft hypothesis, and a scientist taking a copy of her own work before leaving also fits H4. H3 treats the resignation as a coincidence, so it neither predicts nor rules out this item, which on its own discriminates little.
2. New RAT, foreign IP range	C	NA	C	C	NA	H4 rated C on purpose: by itself, an unapproved remote tool calling overseas could be shadow IT (for example, a researcher working with overseas collaborators). Item 6 rules that out. H2 and H5 say nothing about the tool, so NA.
3. Targeted phishing campaign	C	NA	C	I	NA	H4 rated I: the credentials were used from a never-before-seen device two days after the email was opened, which goes against 'the phishing email was not acted on maliciously' (assumption A4: the device has not been verified as a new personal device). Spear-phishing senior scientists with a journal-portal lure fits both H1 and H3.
4. DLP alert, personal cloud upload	C	C	I	C	C	H3 rated I: criminals send stolen data to infrastructure they control, not to an employee's named personal cloud account on her own workstation. H4 rated C because the scenario itself gives a 'policy-violating personal backup habit' as a possible innocent explanation, which item 9 then undermines.
5. No extortion contact or leak-site activity	C	C	I	C	C	Only H3 predicts extortion or resale. The I is soft: this is absence of evidence over a short window, and some criminals hold data or sell it quietly. Espionage actors and insiders do not normally extort.
6. C2 infrastructure overlap with known APT	C	NA	I	I	NA	This is the most diagnostic item for the technical side. It is the only item that says who runs the RAT, and it contradicts both a criminal operator (H3) and an innocent tool (H4). The caveat is that it rests on one SSL-certificate match, attributed with moderate confidence by a second vendor, and certificates are often shared between actors and sometimes planted as false flags. H2 and H5 do not address the RAT, so NA.
7. Counteroffer from an overseas competitor	C	C	NA	C	C	This item feels incriminating and discriminates almost nothing. Moving to a rival is ordinary under H4 and a career step under H2; under H1 the rival is a recruitment route, and under H5 it is the beneficiary. 'Same general region' is too vague to tie the firm to item 2.
8. Misconfigured access control (ACL)	C	C	NA	C	C	The ACL fault explains how she reached the files and says nothing about why, so it fits every hypothesis that involves her. It started about six weeks ago, before the phishing (about three weeks ago), so the intruder did not create it.
9. Content mix of downloaded files (60/40)	C	C	NA	I	C	This is the most diagnostic item for the insider side. H4 rated I: a personal backup of her own work would not include another project's manufacturing-cost and supply-chain files. H2 rated C only because H2 covers data 'useful at her new employer'; commercial cost data from someone else's project fits directed collection (H1, H5) more naturally than career self-interest. H3 does not involve her download, so NA.
10. No other compromised accounts	C	C	I	C	C	A small footprint (one phished account plus the insider) fits a low-and-slow APT and also a lone insider. H3 rated I (soft): double-extortion crews usually move laterally and escalate privileges before stealing data. H4 rated C because 'nothing widespread' is what a false alarm looks like. The phished account's anomaly was already counted under item 3.

Evidence item	H1 State-linked espionage	H2 Independent insider	H3 Cybercriminal intrusion	H4 Benign / false alarm	H5 Competitor-directed insider (added)	Justification / notes
11. Sector-wide phishing wave (ISAC advisory)	**C**	**NA**	**C**	**C**	**NA**	The ISAC advisory fits H1, H3 and H4 (Aurora caught up in a broad wave), so it confirms little. It also lowers the weight of item 3: Aurora was probably not singled out, which makes the timing of the phishing next to the resignation more plausibly coincidental.
E12 [ADDED, derived inference from items 2+4]: Exfiltration channel divergence: insider data left through a DLP-visible personal cloud account, not through the RAT/C2 channel already in the division	**I**	**C**	**NA**	**C**	**C**	This row is my own inference from items 2 and 4, not a scenario fact. H1 rated I only against its coordinated-insider version: a state service with a working implant in the division would not usually have its asset upload through a traceable personal account. The I is soft, because services sometimes keep insiders and implants separate on purpose. H3 rated NA to avoid counting item 4 twice.
Inconsistency tally (count of I ratings)	**1**	**0**	**4**	**3**	**0**	**The tally informs the judgment without deciding it. H2 and H5 reach 0 partly because they are NA on the four technical items they do not explain. H4's three Is carry more weight than H3's four.**

Student-added assumptions (not scenario facts)

- **A1 [ADDED, student assumption]:** The workstation hosting the RAT (item 2) is *not* confirmed to be the resigning scientist's; the scenario says only "the same research division," so I treat the owner as unknown.
- **A2 [ADDED, student assumption]:** The phished scientist (item 3) and the resigning scientist (item 1) are two different people, as item 10 lists them as two separate anomalous accounts.
- **A3 [ADDED, student assumption]:** Reconstructed timeline (day 0 = first evening of bulk download): ACL misconfigured from ~day −42; phishing ~day −21; phished credentials reused ~day −19; RAT installed ~day −10; download on days 0 and 1; resignation ~day 3. The ACL fault therefore predates the intrusion.
- **A4 [ADDED, student assumption]:** The "previously unseen device" in item 3 has not been verified as a new personal device of the phished scientist; if it were, the H4 rating on item 3 would soften to C.

Deliverable 2.2: Analytic report

Clement Ampofo · CIS*6530 · Assignment 2

> **Word count: 1,547** (body text only; excludes the ACH matrix, section headers, and this line)

1. Key judgment

The resigning scientist deliberately took Aurora's intellectual property (**high confidence**), so H4 is rejected. Separately, the remote-access intrusion is more likely state-linked espionage, the technical part of H1, than the work of cybercriminals (**moderate confidence**). Whether that state-linked actor directed the scientist is the most consequential open question, and I can answer it only with **low confidence**: the two activities look concurrent rather than coordinated, which makes an insider acting alone (H2) or for a competitor (H5) somewhat more likely than a fully coordinated H1 operation.

2. Hypothesis set

- H1, state-linked economic espionage: a state-linked or state-tolerated actor is acquiring Aurora's IP for its state's pharmaceutical sector, by intrusion, a co-opted insider, or both.
- H2, independent insider: the scientist, acting on her own initiative, is taking data she believes will help her at her new employer.
- H3, financially motivated cybercriminals: a criminal group got in through the phishing to steal data for extortion or resale, and the resignation is coincidental.
- H4, benign or false alarm: each signal has an innocent explanation and no IP was stolen.
- H5 (added), competitor-directed commercial espionage: the rival firm, acting for its own commercial benefit and without state direction, induced or tasked the scientist during her recruitment to bring specific Aurora data, including manufacturing and supply-chain information. The remote-access intrusion is unrelated.

H5 changes who decides what is taken. In H2 the scientist decides; in H5 a private company does, for corporate goals, and in H1 a state does. That difference produces predictions of its own: contact with the rival before the formal offer, collection matched to the rival's commercial gaps, and no connection to the APT infrastructure.

3. Evidence and diagnosticity

The matrix splits into an insider cluster (items 1, 4, 7, 8 and 9) and a technical cluster (items 2, 3, 6, 10 and 11), with item 5 bearing on both. Few items discriminate at all. Most rows are Consistent with three or four hypotheses and so confirm almost nothing, which leaves three items doing most of the work.

Item 6, the certificate overlap, is the most diagnostic item for the technical cluster. Without it, items 2 and 3 fit H1, H3 and even H4, since an unapproved remote tool can be shadow IT and a login from a new device can be a new phone. Item 6 is the only evidence about who operates the tool: its command servers use a certificate seen before on infrastructure that another vendor attributed to an APT group with a documented

history of targeting pharmaceutical and biotech IP. That makes it Inconsistent with both a criminal operator and an innocent explanation. The weakness is that H1's technical claim rests almost entirely on this one match, attributed second-hand and with moderate confidence. Certificates and hosting are often shared between actors and are sometimes planted as false flags. Because so much depends on one item, my judgment on the technical cluster is moderate rather than high.

Item 9, the 60/40 file mix, does the same job for the insider cluster. A personal backup would contain her own project's files. Forty percent of the download came from a different drug candidate, and those files were manufacturing-cost and supply-chain records, which have little to do with her research. Item 9 is therefore decisively Inconsistent with H4. It is also the only evidence about what the collector wanted. A scientist advancing her own career would value her own research, the 60%. Cost and supply-chain data matter to a business competing with Aurora, or to a state supporting such businesses, so item 9 fits H1 and H5 more naturally than H2, which accommodates it only through its "useful at her new employer" wording. Item 8 limits how far this goes: she reached those files through an accidental ACL fault, and grabbing whatever happened to be reachable explains the mix as well as a shopping list would.

The third discriminator is item 4, the personal cloud upload, together with my derived row E12. Criminals send stolen data to their own infrastructure, not to an employee's named account, so item 4 counts against H3. It also shows that the two channels diverge. If the actor running the RAT were also running her, it already had a covert channel inside her division, and having its asset upload through a traceable personal account that DLP flagged would be poor tradecraft for a state service. Handlers do sometimes keep insiders and implants apart on purpose, and inexperienced assets make mistakes, so the point is not conclusive. It is still the only evidence that bears directly on coordination, and it points away from it.

Item 7 is the item that feels most incriminating, a rival firm in the same region as the IP addresses, yet it is Consistent with H1, H2, H4 and H5. Resigning to join a rival is common, and "same general region" is too vague to tie the firm to item 2. Items 1, 8 and 10 are similarly Consistent with almost everything. Item 11 lowers the weight of item 3: the phishing was part of a regional wave across the sector, so Aurora was probably not singled out. That fits an APT and criminals equally, and it makes the closeness in time between the phishing and the resignation easier to accept as coincidence. Item 5 counts only against H3, and it is absence of evidence over a short window.

4. Inconsistencies and what they rule out (or don't)

The tallies are H1 = 1, H2 = 0, H3 = 4, H4 = 3 and H5 = 0. Read literally, they put H2 and H5 in front, but that follows from how the counting works. Both hypotheses explain only the insider cluster and are rated NA on items 2, 3, 6 and 11 because they say nothing about the RAT. Their score of zero means only that nothing in the matrix contradicts them; any complete account built on either one still needs a second actor for the intrusion. H1's low count partly reflects its breadth, because an actor using "intrusion, an insider, or both" is hard to contradict. Its one inconsistency, E12, falls on the coordinated-insider version, which is the version that would justify treating the scientist as a state agent.

H4 has fewer inconsistencies than H3 and is still the more firmly disqualified, because its three are independent and heavy. Item 3's credential reuse could just about be a new device, and item 6 could just about be a mistaken attribution. No backup habit explains item 9, and that item alone disqualifies H4 for the

insider cluster. A benign reading of the technical cluster survives only if item 6 collapses and the unseen device also turns out to be innocent, which I judge unlikely.

H3's four inconsistencies (items 4, 5, 6 and 10) are softer one by one. Criminals sometimes sit on data or sell it quietly, which weakens item 5. A footprint as small as item 10 describes is unusual for them but possible, and criminals do share infrastructure, which weakens item 6. Together they still add up, and nothing in the matrix favors H3 over H1, since items 2, 3 and 11 fit both equally. H3 is unlikely but not excluded. If item 6 fails, it becomes the leading alternative for the technical cluster.

5. Conclusion, confidence, and what would change my mind

My final judgment is compound. I am highly confident that the scientist deliberately removed Aurora IP, including data outside her own project. The RAT activity is, with moderate confidence, state-linked espionage rather than crime. On whether the two are coordinated my confidence is low: an independent insider (H2) or a competitor-directed one (H5) is marginally favored over a coordinated H1, and no current evidence separates H2 from H5. The evidence neither shows that she is a state agent nor rules out a connection between the two activities. It runs out at what the phished account and the RAT accessed, which the scenario does not report.

The single most consequential new fact would be any forensic link between the RAT and the resigning scientist: the tool running on her workstation, her credentials passing through it, or her downloaded files appearing in its traffic. If such a link exists, coordinated H1 becomes the leading hypothesis at moderate-to-high confidence and the case becomes a state-espionage counterintelligence matter. If the RAT host turns out to be the phished scientist's machine and shows no contact with her data, the judgment that the activities are separate gets stronger. A close second is item 6 itself. If its attribution is withdrawn, or the certificate proves to be shared commodity hosting, the technical cluster drops to low confidence between H1 and H3.

I would monitor four indicators next:

- Further connections to the item-2 IP ranges or the matched certificate fingerprint, shared through the ISAC. If other members see the same infrastructure, the campaign is sector-wide rather than aimed at Aurora.
- Repository logs for the phished account and the roughly 40 users exposed by the ACL fault, to establish exactly what the intruder reached.
- Leak sites and criminal marketplaces for the next 60 to 90 days. A late extortion demand would revive H3.
- The rival firm's patent filings, trial registrations, and manufacturing or supplier changes that resemble the second candidate's cost and supply-chain data, along with any sign that it contacted the scientist before the offer. Either would favor H5 or H1 over H2, since H2 does not predict quick corporate use of commercial data.